



Red Hat

Advanced Cluster Security
for Kubernetes

Red Hat Advanced Cluster Security for Kubernetesのご紹介

レッドハット株式会社

Sales/Solution Architect



Red Hat

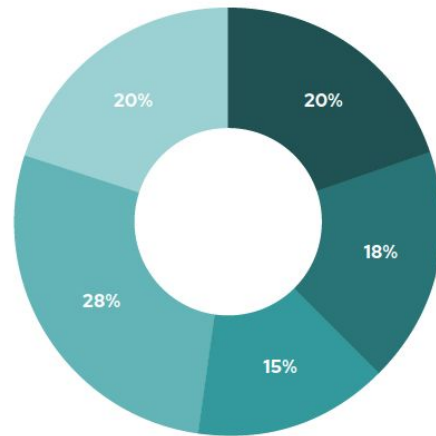
コンテナのセキュリティ対策

コンテナを導入している多くの人がコンテナやKubernetesへのセキュリティの重要性を認識している一方で、組織として具体的な対策を実施している人々は多くありません。

67%

State of Kubernetes security report^[1]によるとコンテナに取り組む人の 67%がセキュリティへの懸念からアプリのデプロイを遅らせたことがあると回答

コンテナ、Kubernetesのセキュリティに対して責任を持つべきチームはどこか？



20%
Ops (architect, platform,
infrastructure, SRE, cloud)

18%
DevOps

15%
DevSecOps

28%
Security (cloud security, security
eng., InfoSec)

20%
Developer



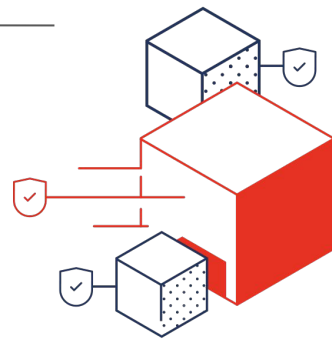
[1]: State of Kubernetes security report 2023 (<https://www.redhat.com/en/resources/state-kubernetes-security-report-2023>)

The vision:

To enable organizations
to securely build, deploy, and run
cloud-native applications

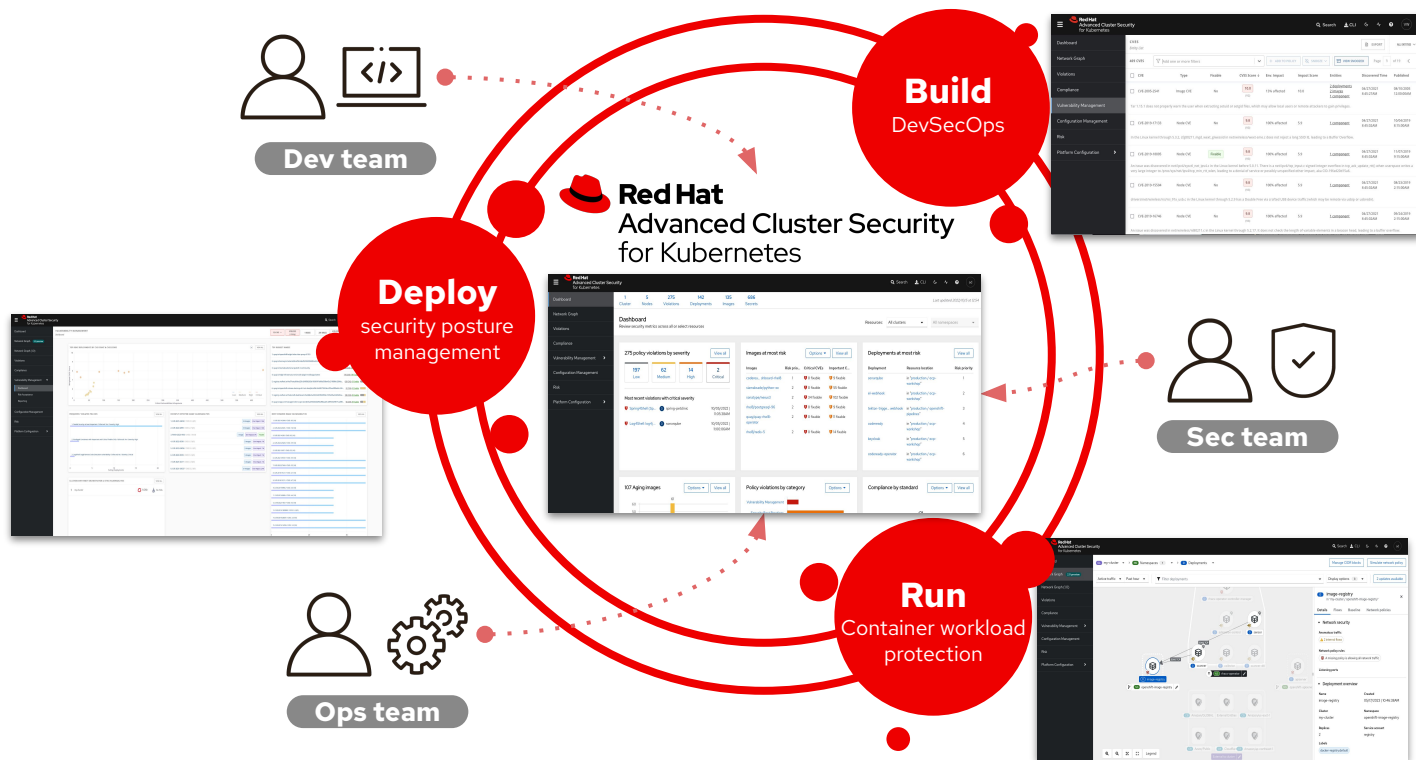
anywhere

組織がクラウドネイティブアプリケーションをどこでも安全に
ビルド、デプロイ、実行できるようにする



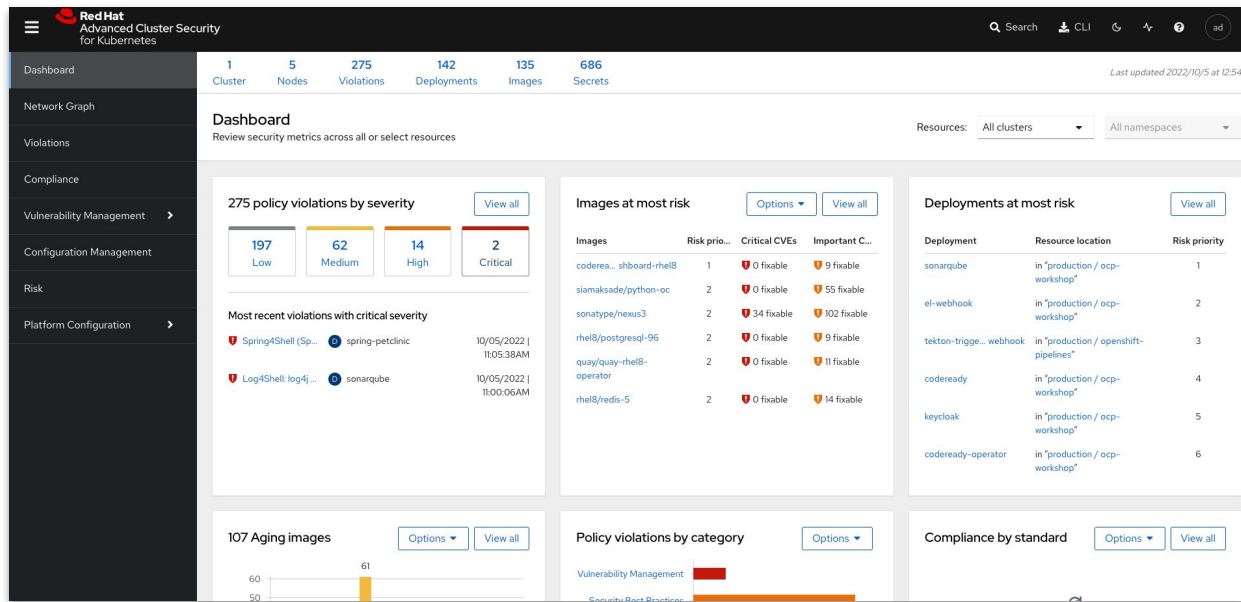
Red Hat Advanced Cluster Security for Kubernetes

The center of open collaboration for container security



RHACSの主要機能

RHACSはコンテナクラスタのライフサイクル全体を保護する統合的なセキュリティプラットフォームとして、様々なセキュリティ機能を提供します



🔍 可視化

一元的なダッシュボードを提供。
全てのイメージ、コンテナ・レジストリ、
Kubernetes Deployment の構成、コンテ
ナ実行時の振る舞い検知

🛡️ リスク・プロファイリング

セキュリティ項目を、影響度や
セキュリティ侵害の可能性に応じて総合
的に判断、対応の優先順位を提示

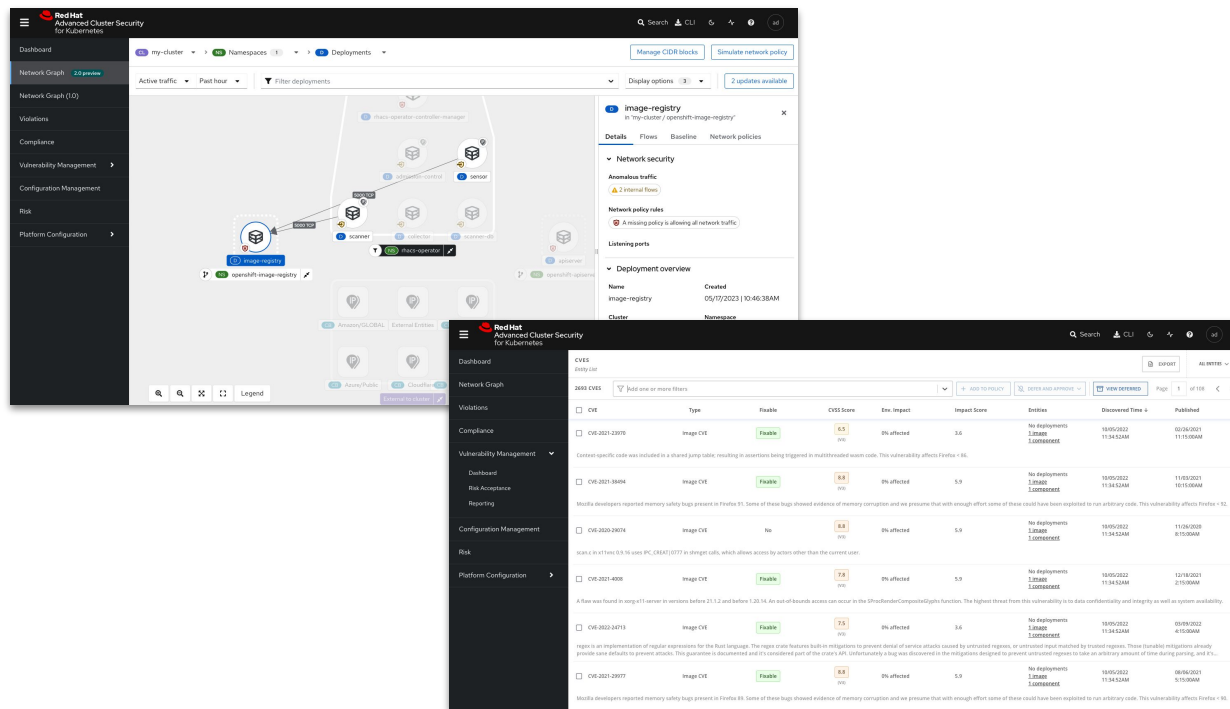
🔑 脆弱性管理

既知の脆弱性の検知。CI/CDパイプライン
や、デプロイされたイメージのスキャン。
CVE / CVSS による可視化。
アプリケーションの安全ではない構成や、課
題な権限の要求のスキャンによる検知。

🔧 構成管理

ポリシーを使った構成の検査。
アプリケーション(Deployment)間で使用さ
れているSecret の検知

RHACSの主要機能



DevSecOps

ビルド時、デプロイ時のセキュリティ・ポリシーの適用。脆弱性や、構成の分析をCI/CD プロセスへ統合。

ネットワーク・セグメンテーション

ビルド時、デプロイ時のセキュリティ・ポリシーの適用。脆弱性や、構成の分析をCI/CD プロセスへ統合。

コンプライアンスと Audit

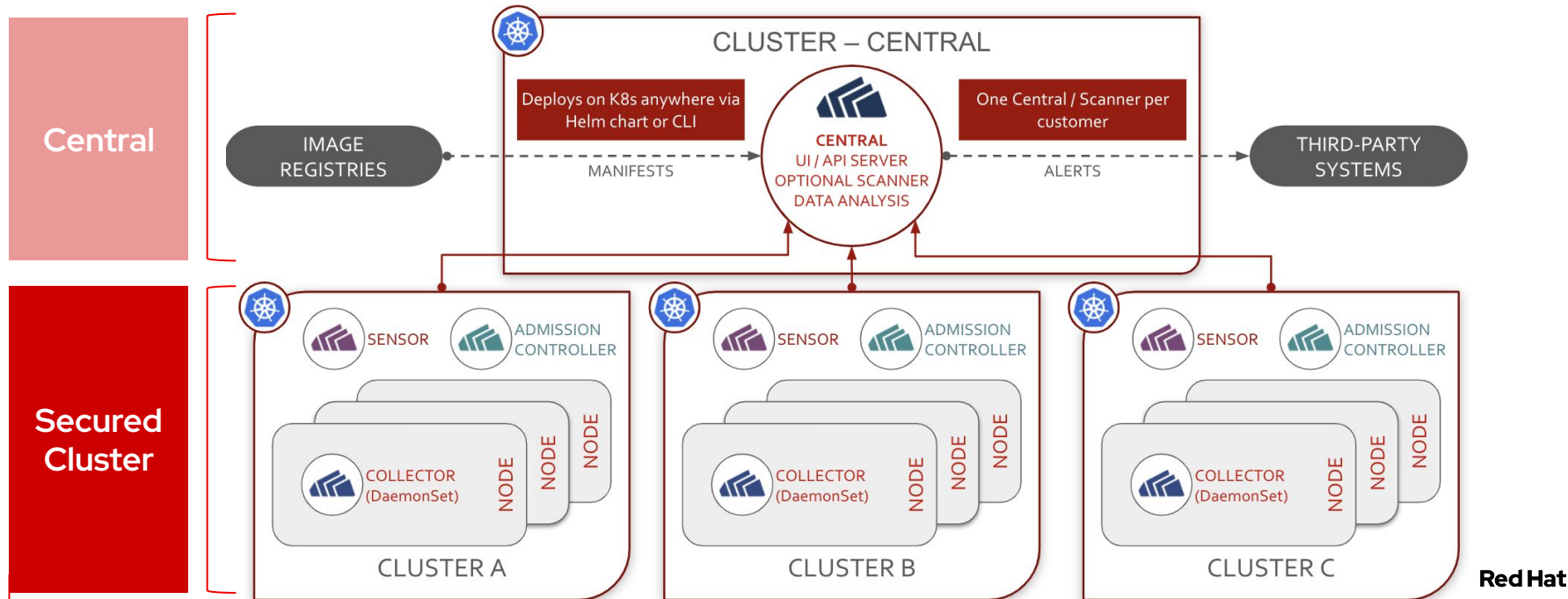
CIS ベンチマーク、NIST、PCI、HIPAA等の300以上のコントロールを使った、継続的なコンプライアンスの評価。

ランタイム検知

ベースラインの振る舞い情報を作成し、シェル実行などの異常な振る舞い時にアラート生成。

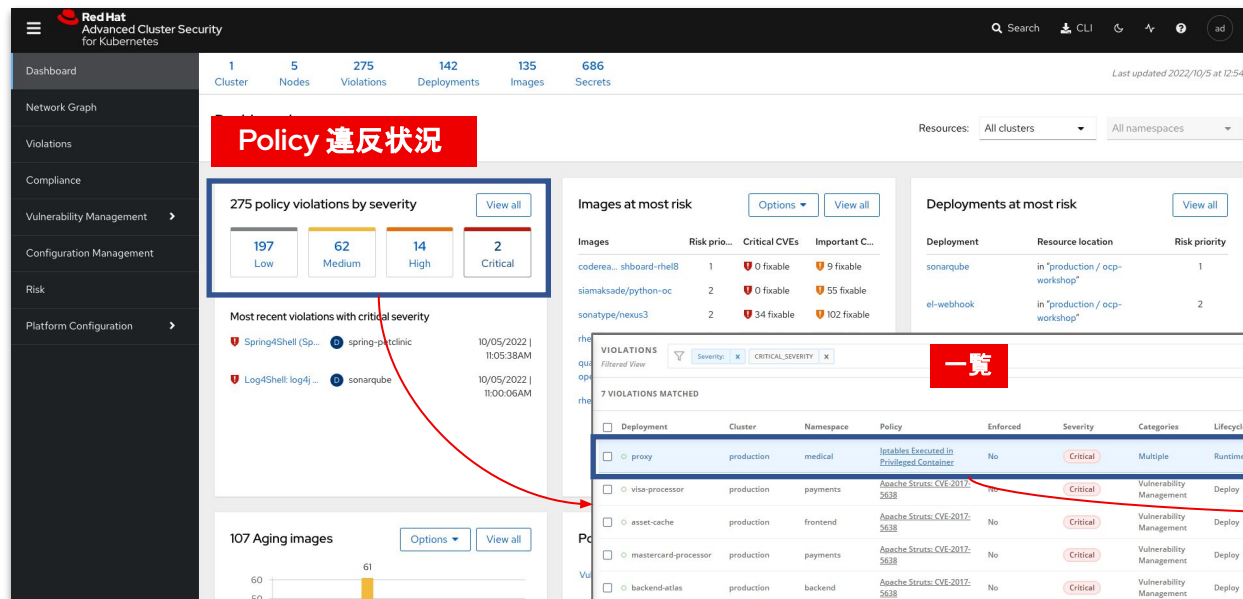
RHACSのアーキテクチャ

RHACSは管理プレーンであるCentralと、管理対象クラスタであるSecured Clusterから構成されます。
単一のCentralから複数のクラスタのセキュリティを管理できます

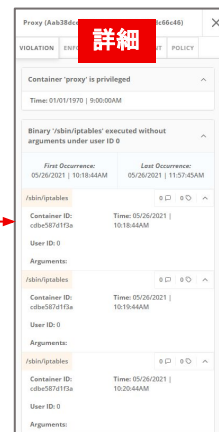


ACSダッシュボード

ACSが把握している状況を一覧で把握するためのメインのダッシュボードです。
表示された内容をドリルダウンしていくことで詳細情報の確認が可能となります。



- デフォルトの Policy、ユーザー定義の Policy の違反状況
- コンプライアンスのベンチマークの遵守状況 (CIS / HIPAA / NIST SP 800-190 / NIST SP 800-53 / PCI DSS)



リスク・プロファイリング

検出されたポリシー違反や脆弱性の全てに対応することは現実的には難しいため、優先順位を付ける必要があります。ACSではこの優先順位付けを自動で実施します。

The screenshot displays the Red Hat Advanced Cluster Security (ACS) interface. The left sidebar contains navigation links: Dashboard, Network Graph, Violations, Compliance, Vulnerability Management, Configuration Management, Risk, and Platform Configuration. The main content area is divided into several sections:

- 35 DEPLOYMENTS**: A table listing deployments with columns for Name, Created, Cluster, Namespace, and Priority. The table is sorted by Priority in ascending order.
- Policy Violations**: A section showing a list of violations, including Log4Shell, Environment Variable Contains Secret, Pod Service Account Token Automatically Mounted, 90-Day Image Age, Latest tag, and Ubuntu Package Manager in Image.
- Process Discovery**: A section showing running processes, including /bin/bash, /bin/rnc, and /usr/bin/dpkg.

Red annotations highlight key features:

- 対応の優先順位**: A red box highlights the Priority column in the deployments table, indicating that ACS automatically assigns priority to violations based on various factors.
- ポリシー違反状況**: A red box highlights the Policy Violations section, showing the details of detected violations.
- プロセス検知**: A red box highlights the Process Discovery section, showing the details of running processes.

A callout box points to the Priority column in the deployments table, stating: "Policy違反、疑わしい Activity、Image の脆弱性、危険な構成、危険なツールのインストール状況、Image の新しさ等の複数の要素を元に対応すべき Priority を提案" (ACS proposes a priority for response based on multiple factors such as policy violations, suspicious activity, image vulnerabilities, dangerous configurations, dangerous tool installation status, and image freshness).

脆弱性管理

環境にデプロイされたコンテナイメージ、ノードOSに含まれる脆弱性(CVE)の情報を表示します。脆弱性の調査で最も時間がかかる、「この脆弱性はどのような脆弱性なのか」「Fixは存在しているのか」といった調査の時間を大幅に削減します。



- 管理環境内の脆弱性の種類を、CVSSスコアや数、Fixが存在しているか等、複数のカットで情報を提供

脆弱性管理(詳細)

検知された脆弱性ごとに、CVSS(Common Vulnerability Scoring System)スコアや、脆弱性の修正が提供されているかといった情報を確認することができます。

329 FIXABLE CVES FOUND ACROSS THIS DEPLOYMENT

EXPORT AS CSV

Page

1

of 14

<

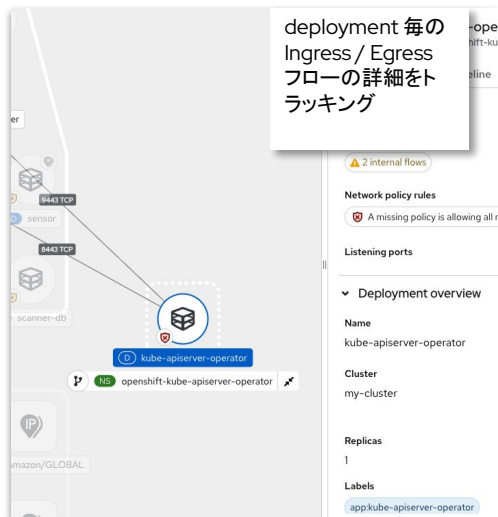
>

CVE番号	Type	修正の提供	CVSSスコア	Env. Impact	Impact Score	Entities	Discovered Time	Published
CVE-2017-10684	Image CVE	Fixable	9.8 (V3)	6% affected	5.9	8 images 4 components	06/14/2021 10:39:12AM	06/30/2017 8:29:00AM
CVE-2018-16839	Image CVE	Fixable	9.8 (V3)	3% affected	5.9	4 images 1 component	06/14/2021 10:40:04AM	11/01/2018 3:29:00AM
CVE-2018-1126	Image CVE	Fixable	9.8 (V3)	6% affected	5.9	7 images 2 components	06/14/2021 10:40:04AM	05/23/2018 10:29:00PM
CVE-2017-14062	Image CVE	Fixable	9.8 (V3)	6% affected	5.9	9 images 4 components	06/14/2021 10:39:12AM	09/01/2017 1:29:00AM
CVE-2018-14618	Image CVE	Fixable	9.8 (V3)	4% affected	5.9	5 images 2 components	06/14/2021 10:40:04AM	09/06/2018 4:29:00AM
CVE-2019-3822	Image CVE	Fixable	9.8 (V3)	3% affected	5.9	4 images 1 component	06/14/2021 10:40:04AM	02/07/2019 5:29:00AM
CVE-2016-9063	Image CVE	Fixable	9.8 (V3)	5% affected	5.9	6 images 2 components	06/14/2021 10:39:12AM	06/12/2018 6:29:00AM

ネットワーク・セグメンテーション

通常時のアプリケーションの通信を監視することで、そこから本来発生し得ない通信を制限するポリシーを自動で作成することができ
ます。

①通常時のネットワークの動きを観測

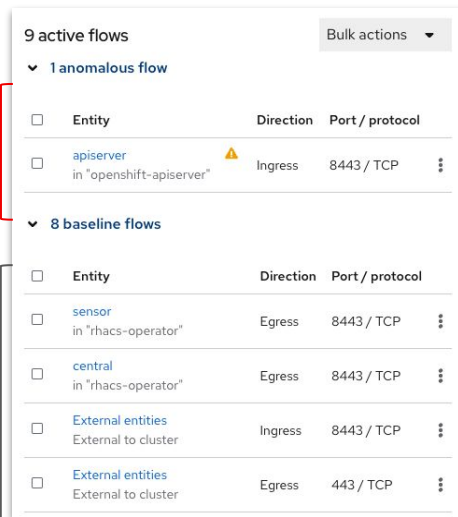


Deployment間、外部とのネットワーク通信を通信方向、プロトコル、ポートで監視

②Baseline flowを作成

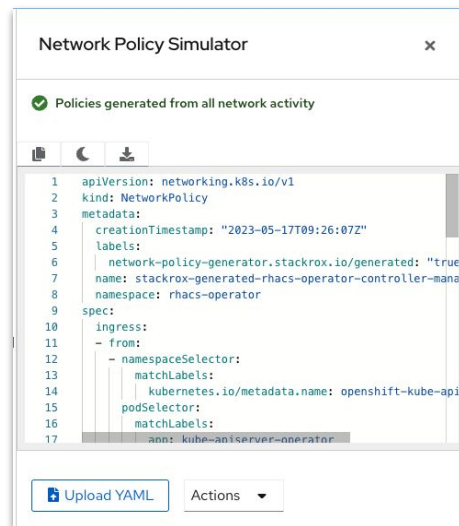
Anomalous flow

Baseline flow



Networkのアクティビティを観察しBaselineを作成。Baseline以外の通信が発生した場合アラート可能

③Network Policyの自動生成



baseline を元に、Kubernetes の Network Policy を自動生成

CIパイプラインでのコンテナイメージスキャン

RHACSは機能の一部としてCLIを提供しています。これをCIパイプラインに組み込むことで、ビルドしたイメージの脆弱性診断や、ポリシーチェックを自動化できます。

- 脆弱性(CVE)+ポリシーチェック
- デフォルトポリシーだけでなくカスタマイズに対応
- 診断結果の詳細をRHACSコンソールから確認可能

```
# roxctl image check -e=$ROX_CENTRAL_ADDRESS --token-file=acs-token --output=table --image=registry.redhat.io/rhel8/nodejs-16:latest
...
```

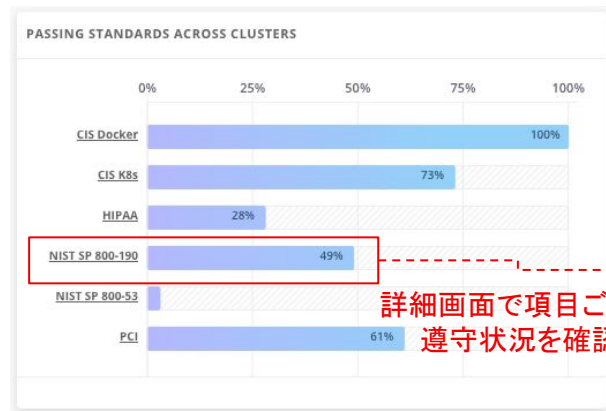
Policy check results for image: registry.redhat.io/rhel8/nodejs-16:latest
(TOTAL: 2, LOW: 2, MEDIUM: 0, HIGH: 0, CRITICAL: 0)

ポリシーの説明				違反理由	修正方法
POLICY	SEVERITY	BREAKS BUILD	DESCRIPTION	VIOLATION	REMEDATION
Latest tag	LOW	-	Alert on deployments with images using tag 'latest'	- Image has tag 'latest'	Consider moving to semantic versioning based on code releases (semver.org) or using the first 12 characters of the source control SHA. This will allow you to tie the Docker image to the code.
Red Hat Package Manager in Image	LOW	-	Alert on deployments with components of the Red Hat/Fedora/CentOS package management system.	- Image includes component 'dnf' (version 4.7.0-4.el8.noarch) - Image includes component 'rpm' (version 4.14.3-19.el8.x86_64) - Image includes component 'yum' (version 4.7.0-4.el8.noarch)	Run <code>'rpm -e --nodeps \$(rpm -qa '*rpm*' '*dnf*' '*libsolv*' '*hawkey*' 'yum*')</code> in the image build for production containers.

WARN: A total of 2 policies have been violated

コンプライアンスの管理

クラスタ単位、Namespace単位、ノード単位でコンプライアンスへの遵守状況を可視化し表示します。
得られた結果についてはCSV、PDF形式でレポートとしても出力可能です。



対応する規格

- CIS Docker
- CIS K8s
- HIPAA
- NIST SP 800-190
- NIST SP 800-53
- PCI-DSS

mycluster2		14 CONTROLS
Control ↑	Compliance	
4.1.1 - Image Vulnerabilities Organizations should use tools that take the pipeline-based build approach and immutable nature of containers and images into their design to provide more actionable and reliable results. Key aspects of effective tools and processes include: 1. Integration with the entire lifecycle of images, from the beginning of the build process, to whatever registries the organization is using, to runtime. 2. Visibility into vulnerabilities at all layers of the image, not just the base layer of the image but also application frameworks and custom software the organization is using. Visibility should be centralized across the organization and provide flexible reporting and monitoring views aligned with organizations' business processes. 3. Policy-driven enforcement; organizations should be able to create "quality gates" at each stage of the build and deployment process to ensure that only images that meet the organization's vulnerability and configuration policies are allowed to progress. For example, organizations should be able to configure a rule in the build process to prevent the progression of images that include vulnerabilities with Common Vulnerability Scoring System (CVSS) [18] ratings above a selected threshold.	100%	
4.1.2 - Image configuration defects Organizations should adopt tools and processes to validate and enforce compliance with secure configuration best practices. For example, images should be configured to run as non-privileged users. Tools and processes that should be adopted include: 1. Validation of image configuration settings, including vendor recommendations and third-party best practices. 2. Ongoing, continuously updated, centralized reporting and monitoring of image compliance state to identify weaknesses and risks at the organizational level. 3. Enforcement of compliance requirements by optionally preventing the running of non-compliant images. 4. Use of base layers from trusted sources only, frequent updates of base layers, and selection of base layers from minimalistic technologies like Alpine Linux and Windows Nano Server to reduce attack surface areas. A final recommendation for image configuration is that SSH and other remote administration tools designed to provide remote shells to hosts should never be enabled within containers. Containers should be run in an immutable manner to derive the greatest security benefit from their use. Enabling remote access to them via these tools implies a degree of change that violates this principle and exposes them to greater risk of network-based attack. Instead, all remote management of containers should be done through the container runtime APIs, which may be accessed via orchestration tools, or by creating remote shell sessions to the host on which the container is running.	0%	

結果をCSV
またはPDFで出力

項目ごとに%表示

外部システムとの連携

RHACSのコンソールよりイメージスキャンの対象とするコンテナレジストリを追加したり、アラートの通知先を設定することができます。
またAPIリファレンスも公開しており、APIによる連携も可能となります。

スキャン対象のレジストリ追加

Image Integrations

 StackRox StackRox Scanner Image Scanner + Node Scanner	 docker Generic Docker Registry Registry	 aws Amazon ECR Registry	 Google Container Registry Registry + Scanner	 Google Artifact Registry Registry
 Azure Microsoft ACR Registry	 JFrog ARTIFACTORY JFrog Artifactory Registry	 Red Hat Quay.io Quay.io Registry + Scanner	 clair CoreOS Clair Scanner	 Nexus Sonatype Nexus Registry
 IBM Cloud Container Registry Registry	 Red Hat Red Hat Registry			

アラート通知先の設定

Notifier Integrations

 slack Slack	 StackRox Generic Webhook	 Jira Software Jira	 email Email	 Google Cloud Platform Google Cloud SCC
 splunk Splunk	 pagerduty PagerDuty	 sumo logic Sumo Logic	 Microsoft Teams Microsoft Teams	 AWS Security Hub AWS Security Hub
 Syslog Syslog				

ユーザー導入事例: Cigna

開発スピードとセキュリティの両立

Cignaはアメリカコネチカット州に本社を置く世界的な医療サービス企業です。自社ビジネスを素早く変革するためコンテナとOpenShiftを採用しており、自社のデジタル化を推進してきました。

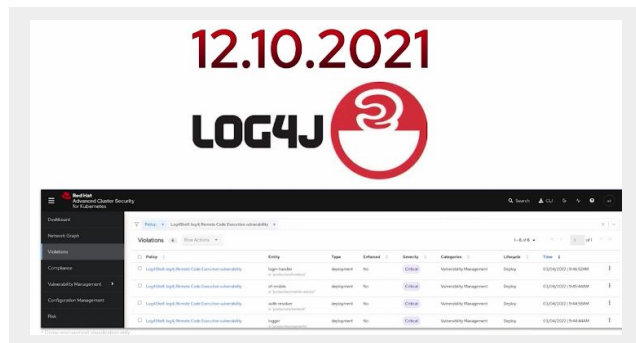
しかし、課題も...

- ・ 自社内で新規アプリ開発が活発になりデプロイ頻度が増えた一方で、過去に開発したアプリのメンテナンスが課題に
- ・ 利用規模が増えどのクラスターでどのバージョンのアプリが動いているかなどの把握が困難化
- ・ Log4jに代表される新たに見つかるセキュリティ脆弱性への素早い対応
- ・ 開發生産性の向上とセキュリティ対策の両立

拡張性の高い包括的コンテナセキュリティ

全社で700ノード、23000CPUコアを超えるクラスターのセキュリティ設定・ポリシーをコード化し集中管理。

- Red Hat Advanced Cluster Security (RHACS)を採用していたことでLog4j脆弱性にも素早く対応することができた



ユーザー導入事例: Cigna

包括的なコンテナセキュリティ



これまでの私達のセキュリティ対策では実際に起こり得る脆弱性の問題に対して不十分であると気付けたことは大きな学びでした。

Q. Log4j脆弱性に対応するにあたりレッドハットのソリューションはどのように役立ちましたか？

この問題が起きた時、会社の経営層から現場の開発者までこの脆弱性の問題が私達にもたらす影響を知りたがりました。

私達が採用していた Red Hat Advanced Cluster Securityは、システム全体の中で問題箇所を自動的に特定し、迅速に対応することを可能としました。

Cigna



Thank you

Red Hat is the world's leading provider of enterprise open source software solutions. Award-winning support, training, and consulting services make Red Hat a trusted adviser to the Fortune 500.



linkedin.com/company/red-hat



youtube.com/user/RedHatVideos



facebook.com/redhatinc



twitter.com/RedHat